

California S.B. 1386 was a bill passed by the California legislature that amended the California law regulating the privacy of personal information: civil codes 1798.29, 1798.82 and 1798.84. This was an early example of many future U.S. and international security breach notification laws, it was introduced by California State Senator Steve Peace on February 12, 2002, and became operative July 1, 2003.

Sections

Enactment of a requirement for notification to any resident of California whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. This requires an agency, person or business that conducts business in California and owns or licenses computerized 'personal information,' to disclose any breach of security (to any resident whose unencrypted data is believed to have been disclosed).

The bill mandates various mechanisms and procedures with respect to many aspects of this scenario, subject also to other defined provisions.

Any agency that owns or licenses computerized data that includes personal information shall disclose any breach of the security of the system following discovery or notification of the breach in the security of the data to any resident of California whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. An out-of-state corporation that has personal information relating to a California resident would fall under this statute. A question on minimum contacts would then ensue as to whether an action may be brought in California to enforce the California resident's rights under the statute.

Corporations with no physical locations in California are not subject to California law. That SB 1386 would affect an out-of-state corporation is based on the notion of 'quasi in rem' jurisdiction, a notion that the Supreme Court invalidated in *Shaffer v. Heitner*.

Corporations can determine whether they are subject to this statute by reviewing the

following questions:

Does their data include "personal information" as defined by the statute?

Does that "personal information" relate to a California resident?

Was the "personal information" unencrypted?

Was there a "breach of the security" of the data as defined by the statute?

Was the "personal information" acquired, or is reasonably believed to have been acquired, by an unauthorized person?

A corporation that answers yes to all five of these questions must report.

The statute does not apply to "encrypted" information. Thus one way to avoid reporting is to encrypt all "personal information." A corporation can also avoid reporting if its data does not contain "personal information" relating to a California resident.

"Personal information" means an individual's first name or first initial and last name in combination

with any one or more of the following data elements, when either the name or the data elements are not encrypted:

Social security number.

Driver's license number or California Identification Card number.

Account number, credit or debit card number, in combination with any required security code, access code, or password that would permit access to an individual's financial account.

"Personal information" does not include publicly available information that is lawfully made available to the general public from federal, state, or local government records.

References

External links

Text of SB1386

The SB 1386 Management Toolkit